

Cybersecurity Daily Newsletter

Vol. 005 | 2026-09-28 09:00 WIB

Top 5 Highlights

- Citrix confirms two NetScaler RCE zero-days exploited in attacks
- Cloudflare fixes Containers cross-tenant flaw exposing customer data
- [+24h Old] Frequently asked questions about reported Citrix NetScaler zero-day vulnerabilities
- [+24h Old] Microsoft SharePoint Flaw CVE-2026-65660 Now Exploited in Attacks
- [+24h Old] Week in review: Gyazo breach exposes 23.6M user data, TASK#STOMP steals documents

Threat Intelligence (10)

01. [+24h Old] Lunex Stealer Abuses AMD Driver to Disable Security Monitoring and Steal Browser Credentials

The Psychedelic Stealer malware distributed via compromised Ukrainian websites using ClickFix-style Cloudflare verification checks is part of a wider malware-as-a-service (MaaS) platform called Lunex. The new findings come from Ontinue, which described the activity as a four-stage attack chain aimed at targeting Ukrainian-speaking users. "The attack chain b...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/lunex-stealer-abuses-amd-driver-to.html>

02. [+24h Old] GitHub Actions re-enabled with Mini Shai-Hulud payload still active

Two third-party GitHub Actions previously compromised in a Mini Shai-Hulud campaign were re-enabled by their maintainer and remained accessible for more than a week despite still pointing to malicious code. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/github-actions-re-enabled-with-mini-shai-hulud-payload-still-active/>

03. [+24h Old] New x47.c Windows Botnet Weaponizes xAI Grok, AI API Draining

The Windows botnet relies on AI to maintain persistence, using xAI Grok to choose from predefined actions. The post New x47.c Windows Botnet Weaponizes xAI Grok, AI API Draining appeared first on SecurityWeek .

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.securityweek.com/new-x47-c-windows-botnet-weaponizes-xai-grok-ai-api-draining/>

04. [+48h Old] Researchers identify AliExpress-themed phishing campaign using disposable domains

EfficientIP Research Labs identified potential .cyou domains on June 9 that were later registered and began resolving to IP addresses on July 2.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.scworld.com/brief/researchers-identify-aliexpress-themed-phishing-campaign-using-disposable-domains>

05. [+48h Old] Compromised GitHub Actions re-enabled, posing supply chain risks

The compromised GitHub Actions were originally disabled on May 18, 2026, after being found to execute malicious code that harvested sensitive credentials from CI/CD pipelines.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Audit build pipelines, rotate CI/CD secrets, enforce package integrity controls, and review developer workstation hardening.

Sources:

<https://www.scworld.com/brief/compromised-github-actions-re-enabled-posing-supply-chain-risks>

06. [+48h Old] New PamStealer variant uses server-side decryption for macOS malware

The latest PamStealer variant, observed by Jamf Threat Labs, continues to use a JavaScript for Automation (JXA) dropper but has updated its lure and delivery mechanisms.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources:

<https://www.scworld.com/brief/new-pamstealer-variant-uses-server-side-decryption-for-macos-malware>

07. [+48h Old] Fake Google Security Team ad says 'no script reading' in voice phishing - then prints the script

More mockery and memes from the Dark Web Roast

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Tighten email authentication and filtering, run targeted user awareness, and monitor for lookalike domains and suspicious inbox rules.

Sources: <https://www.theregister.com/security/2026/09/25/fake-google-security-team-ad-says-no-script-reading-in-voice-phishing-then-prints-the-script/5299264>

08. [+48h Old] Kothamine malware uses Tailscale's tailcat to evade network detection

Kothamine uses a legitimate Tailscale tool to receive attackers' commands through an encrypted connection with no malicious domain to block.

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.malwarebytes.com/blog/threat-intel/2026/09/kothamine-malware-uses-tailscales-tailcat-to-evade-network-detection>

09. [+48h Old] With the Rise of AI Agents, SOC 2 Should Adapt or Risk Irrelevance

AI agents can operate through human credentials and take actions that existing SOC 2 controls may not distinguish from human activity. Token Security explains why SOC 2 needs to adapt to address the security gaps created by agent identities. [...]

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://www.bleepingcomputer.com/news/security/with-the-rise-of-ai-agents-soc-2-should-adapt-or-risk-irrelevance/>

10. [+48h Old] Compromised GitHub Actions Came Back Online and Resumed Executing Mini Shai-Hulud Malware

Two actions-cool GitHub Actions have been disabled for a second time after the repositories became accessible last week, months after they were compromised during the May 2026 Mini Shai-Hulud campaign. The affected GitHub Actions are listed below - actions-cool/issues-helper actions-cool/maintain-one-comment Visiting either of the repositories now shows the...

Why it matters: Threat-actor tradecraft and active campaigns help defenders anticipate techniques likely to be used against their environment.

Recommendation: Update detections and threat hunts using reported TTPs/IOCs, review email/web controls, and harden high-risk internet-facing services.

Sources: <https://thehackernews.com/2026/09/compromised-github-actions-came-back.html>

Latest Vulnerabilities (10)

01. Citrix confirms two NetScaler RCE zero-days exploited in attacks

Citrix has confirmed that two critical NetScaler remote code execution vulnerabilities, tracked as CVE-2026-88771 and CVE-2026-88772, are being exploited in attacks and that it has released security updates to fix the flaws. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/citrix-admins-warned-to-shut-down-netscaler-s-over-2-exploited-zero-days/>

02. Cloudflare fixes Containers cross-tenant flaw exposing customer data

Cloudflare has fixed a vulnerability in Containers and Sandboxes that allowed customers with a Workers Paid account to recover residual data from other customers' containers on the same physical host. [...]

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://www.bleepingcomputer.com/news/security/cloudflare-fixes-containers-cross-tenant-flaw-exposing-customer-data/>

03. [+24h Old] Frequently asked questions about reported Citrix NetScaler zero-day vulnerabilities

CVE-2026-88771 and CVE-2026-88772, two zero-day vulnerabilities in Citrix NetScaler, have been confirmed as exploited in the wild. Citrix released patches on September 27, 2026. Change log Update September 27: Citrix published security bulletin CTX697096, confirming CVE-2026-88771 and CVE-2026-88772 as the two zero-day RCE vulnerabilities and releasing patc...

Why it matters: Publicly discussed 0-days often see rapid weaponization, increasing the risk of opportunistic attacks at scale.

Recommendation: Apply vendor guidance immediately, reduce attack surface, and monitor for IoCs/exploitation telemetry until patches are fully deployed.

Sources: <https://www.tenable.com/blog/frequently-asked-questions-about-reported-citrix-netscaler-zero-day-vulnerabilities>

04. [+24h Old] Microsoft SharePoint Flaw CVE-2026-65660 Now Exploited in Attacks

CISA added CVE-2026-65660 to its KEV catalog, giving federal agencies a patching deadline of September 28. The post Microsoft SharePoint Flaw CVE-2026-65660 Now Exploited in Attacks appeared first on SecurityWeek .

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources:

<https://www.securityweek.com/microsoft-sharepoint-flaw-cve-2026-65660-now-exploited-in-attacks/>

05. [+24h Old] Warning: Two Unpatched Citrix NetScaler RCE Zero-Days Under Active Exploitation

Two critical vulnerabilities in Citrix NetScaler ADC and NetScaler Gateway that allow remote code execution have been exploited in the wild, Citrix confirmed on September 27. It released fixes for both, along with six other flaws. One of the two affects every deployment on an affected version, including those in the default configuration. The bulletin came...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://thehackernews.com/2026/09/warning-two-unpatched-citrix-netscaler.html>

06. [+24h Old] SEC Consult SA-20260923-0 :: Local Privilege Escalation in Honeywell IQ MultiAccess Update Service #CVE-2026-13742

Posted by SEC Consult Vulnerability Lab via Fulldisclosure on Sep 26 SEC Consult Vulnerability Lab Security Advisory =====

===== title: Local Privilege Escalation product: Honeywell IQ MultiAccess Update Service vulnerable version: IQ V27 & IQ V28 fixed version: IQ V27 SP1 & IQ V28 SP1 CVE number:...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Sep/88>

07. [+24h Old] [SYSS-2026-071]: GDCM (Grassroots DICOM) - Format String (CWE-134)

Posted by Matthias Deeg via Fulldisclosure on Sep 26 Advisory ID: SYSS-2026-071 Product: GDCM (Grassroots DICOM) Manufacturer: GDCM Project Affected Version(s): 3.3.0 Tested Version(s): 3.3.0 Vulnerability Type: Format String (CWE-134) Risk Level: Medium Solution Status: Open Manufacturer Notification: 2026-07-24 Public Disclosure: 2026-09-23 CVE Reference:...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Sep/87>

08. [+24h Old] [SYSS-2026-070]: GDCM (Grassroots DICOM) - Integer Overflow (CWE-190)

Posted by Matthias Deeg via Fulldisclosure on Sep 26 Advisory ID: SYSS-2026-070 Product: GDCM (Grassroots DICOM) Manufacturer: GDCM Project Affected Version(s): 3.3.0 Tested Version(s): 3.3.0 Vulnerability Type: Integer Overflow (CWE-190) Risk Level: High Solution Status: Open Manufacturer Notification: 2026-07-24 Public Disclosure: 2026-09-23 CVE Reference:...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Sep/86>

09. [+24h Old] [SYSS-2026-068]: GDCM (Grassroots DICOM) - Stack-based Buffer Overflow (CWE-121)

Posted by Matthias Deeg via Fulldisclosure on Sep 26 Advisory ID: SYSS-2026-068

Product: GDCM (Grassroots DICOM) Manufacturer: GDCM Project Affected Version(s):

3.3.0 Tested Version(s): 3.3.0 Vulnerability Type: Stack-based Buffer Overflow (CWE-121)

Risk Level: High Solution Status: Open Manufacturer Notification: 2026-07-24 Public

Disclosure: 2026-09-23 CV...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Sep/84>

10. [+24h Old] harness Gitspace hardcoded password for every user account

Posted by Khashayar Fereidani on Sep 26 # harness Gitspace hardcoded password for every user account **Author:** Khashayar Fereidani **Disclosure Date:** 2026-09-24

Advisory:

<https://fereidani.com/harness-gitspace-hardcoded-password-for-every-user-account>

Contact: <https://fereidani.com/contact> ## Description Gitspaces are Harness's hosted developmen...

Why it matters: Exploit-ready vulnerabilities can rapidly translate into compromise-especially for internet-facing services and widely deployed products.

Recommendation: Prioritize patching/mitigations, review exposure, and add detection for exploitation attempts (e.g., WAF/EDR signatures and logs).

Sources: <https://seclists.org/fulldisclosure/2026/Sep/83>

Data Breach & Cybercrime (10)

01. [+24h Old] Week in review: Gyazo breach exposes 23.6M user data, TASK#STOMP steals documents

Here's an overview of some of last week's most interesting news, articles, interviews and videos: Know what was tested before your SAP ECC migration goes live In this Help Net Security interview, Guilherme Joventino, COO of MIGNOW, explains why some large companies plan to stay on ECC past the 2027 deadline and pay SAP for extended support until 2030. The i...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.helpnetsecurity.com/2026/09/27/week-in-review-gyazo-breach-exposes-23-6m-user-data-taskstomp-steals-documents/>

02. [+48h Old] Bitget loses \$351.6 million in suspected North Korean crypto hack

The breach was discovered on Thursday evening when security systems detected unauthorized transfers.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.scworld.com/brief/bitget-loses-351-6-million-in-suspected-north-korean-crypto-hack>

03. [+48h Old] U.S. Soldier Gets 70 Months in Prison for AT&T, Verizon Extortions

A U.S. Army soldier who pleaded guilty to hacking into multiple telecommunications companies and stealing mobile call and text metadata for more than 100 million AT&T customers in 2024 was sentenced to 70 months in federal prison today and ordered to pay nearly \$300,000 in restitution to victims.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://krebsonsecurity.com/2026/09/u-s-soldier-gets-70-months-in-prison-for-att-verizon-extortions/>

04. [+48h Old] ShinyHunters tells The Reg: We hacked the FBI to 'protect our business'

Data theft and extortion biz, that is

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.theregister.com/cyber-crime/2026/09/25/shinyhunters-tells-the-reg-we-hacked-the-fbi-to-protect-our-business/5299250>

05. [+48h Old] In Other News: Clop Leak Site Takeover, Docker Botnet Hunts AI Keys, Water Utility Exposure

Noteworthy stories that might have slipped under the radar: BragJack attack against browser AI assistants, TDengine flaw threatens industrial telemetry uptime, Ubuntu update overhaul. The post In Other News: Clop Leak Site Takeover, Docker Botnet Hunts

AI Keys, Water Utility Exposure appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/in-other-news-clop-leak-site-takeover-docker-botnet-hunts-ai-keys-water-utility-exposure/>

06. [+48h Old] LinkedIn adds new checks for fake profiles and work histories

The platform is adding new checks as AI makes profiles easier to forge. But scammers can still invent a company to recruit for.

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.malwarebytes.com/blog/news/2026/09/linkedin-adds-new-checks-for-fake-profiles-and-work-histories>

07. [+48h Old] Kosovar Owner of Rydlox Marketplace Pleads Guilty in US Court

Ardit Kutleshi created and operated Rydlox, which allowed miscreants to trade PII and cybercrime tools and services. The post Kosovar Owner of Rydlox Marketplace Pleads Guilty in US Court appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.securityweek.com/kosovar-owner-of-rydlox-marketplace-pleads-guilty-in-us-court/>

08. [+48h Old] Rydlox marketplace admin pleads guilty, faces 22 years in prison

A Kosovar national has pleaded guilty to operating Rydlox, a large illegal online marketplace that sold stolen personal information, login credentials, credit card details, and cybercrime tools. [...]

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://www.bleepingcomputer.com/news/security/rydlox-marketplace-admin-pleads-guilty-faces-22-years-in-prison/>

09. [+48h Old] Windows, Linux, Android File Notification Systems Leak User Activity

Researchers show that file-change notification systems can leak keystroke timing, browsing activity, and WhatsApp media events. The post Windows, Linux, Android File

Notification Systems Leak User Activity appeared first on SecurityWeek .

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources:

<https://www.securityweek.com/windows-linux-android-file-notification-systems-leak-user-activity/>

10. [+48h Old] Bitget Says Suspected North Korean Hackers Stole \$351.6M After Backend Compromise

Cryptocurrency exchange Bitget said suspected North Korean threat actors have stolen \$351.6 million from its hot and warm wallets. "At 18:31 UTC on September 24, 2026, Bitget's security systems identified unauthorized transfers involving a limited number of hot wallets," BitGet said in a post shared on X. "Bitget's cold wallets and the overwhelming majority...

Why it matters: Breaches and cybercrime activity signal where attackers are focusing and what data types are actively monetized.

Recommendation: Validate incident-response readiness, monitor for exposed credentials, and reinforce MFA, phishing resistance, and data-loss controls.

Sources: <https://thehackernews.com/2026/09/bitget-says-suspected-north-korean.html>